

Cache poisoning/XSS via color scheme cookies

Cache poisoning/XSS via color scheme cookies - Author not stated, GitHub Advisory Database.

- Published: 2026-07-28
- Original: <<https://github.com/discourse/discourse/security/advisories/GHSA-qx4v-rg4v-pm2g>>
- Preserved from: <https://github.com/discourse/discourse/security/advisories/GHSA-qx4v-rg4v-pm2g> (github-api) on 2026-10-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Cache poisoning/XSS via color scheme cookies

- Advisory: GHSA-qx4v-rg4v-pm2g
- CVE: CVE-2026-55674
- Severity: critical
- Published: 2026-07-28
- Updated: 2026-07-28

Affected

- `Discourse` (other): ≥ 0
- `Discourse` (other): $\geq 2026.6.0$ -latest
- `Discourse` (other): $\geq 2026.5.0$ -latest
- `Discourse` (other): $\geq 2026.1.0$ -latest

Description

Impact

An unauthenticated attacker could send a single request with a crafted `color_scheme_id` (or `dark_scheme_id`) cookie to inject arbitrary HTML into a Discourse page. Because the cookie value was rendered into a color scheme `<link>` tag without escaping, the attacker could break out of the attribute and inject a `<link rel="modulepreload">` tag that bypassed Discourse's nonce-based Content Security Policy, resulting in arbitrary JavaScript execution in visitors' browsers.

Since these cookies were not part of the anonymous cache key, the poisoned response was cached and served to all subsequent anonymous visitors (scoped per User-Agent), turning a single request into a persistent stored XSS affecting all anonymous users. No authentication or user interaction is required. Successful exploitation could lead to session/credential theft, redirection, phishing, or full client-side compromise.

Patches

Latest discourse version.

Workarounds

N/A

Archived from <https://github.com/discourse/discourse/security/advisories/GHSA-qx4v-rg4v-pm2g>. Rendered offline from the local Markdown copy.